

Advertisement

SECURITY



How we found TeaOnHer
spilling users' driver's
licenses in less than 10
minutes

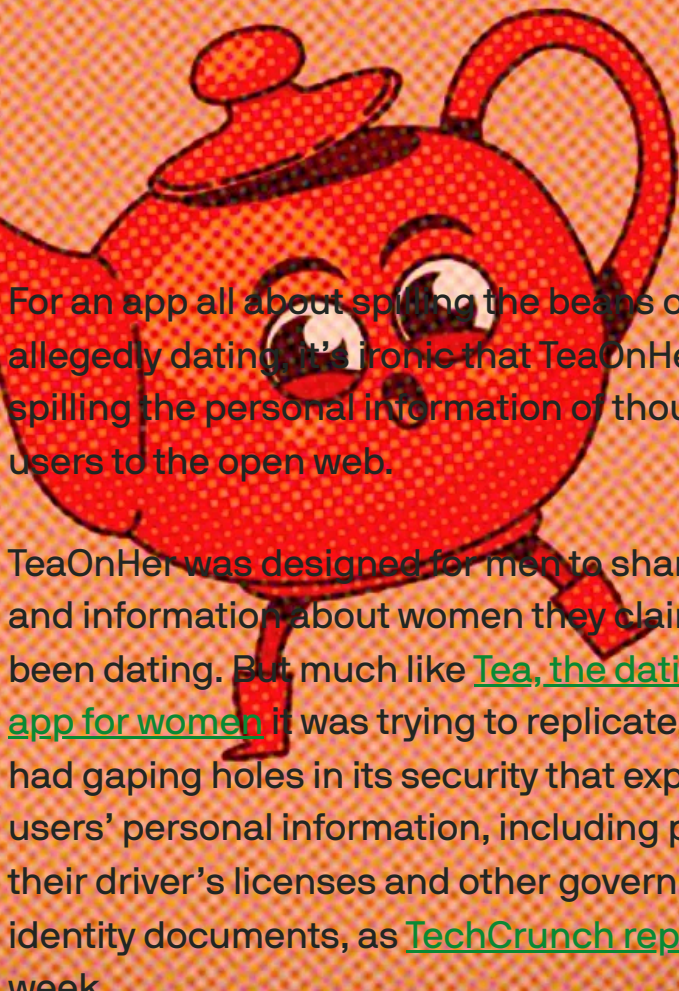


IMAGE CREDITS: TEAONHER (MODIFIED)

For an app all about spilling the beans on who you're allegedly dating, it's ironic that TeaOnHer was spilling the personal information of thousands of its users to the open web.

TeaOnHer was designed for men to share photos and information about women they claim to have been dating. But much like [Tea, the dating-gossip app for women](#) it was trying to replicate, TeaOnHer had gaping holes in its security that exposed its users' personal information, including photos of their driver's licenses and other government-issued identity documents, as [TechCrunch reported](#) last week.

These gated community-like apps were created ostensibly to let users share information about their relationships under the guise of personal safety. However, shoddy coding and security flaws highlight the ongoing privacy risks inherent in requiring users to submit sensitive information to use apps and websites.

Such risks are only going to worsen; popular apps and web services are already having to [comply with age-verification laws](#) that require people to [submit their identity documents](#) before they can be granted access to adult-themed content, despite the privacy and security risks associated with storing databases of people's personal information.

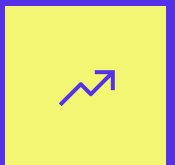
TEC DISRUPT

October 27-29, 2025 | San Francisco

Put your brand in front of 10,000+ tech and VC leaders across all three days of Disrupt 2025. Amplify your reach, spark real connections, and lead the innovation charge. Secure your exhibit space before your competitor does.

[Book Your Table >](#)

Most Popular



- [HR giant Workday says hackers stole personal data in recent breach](#)
- [How your solar rooftop became a national security issue](#)
- [A comprehensive list of 2025 tech layoffs](#)
- [Co-founder of Elon Musk's xAI departs the company](#)
- [Google CEO adds a new calendar feature at Stripe co-founder's request](#)

When TechCrunch published our story last week, we did not publish specific details of the bugs we discovered in TeaOnHer, erring on the side of caution so as to not help bad actors exploit the bug. Instead, [we decided to publish a limited disclosure](#), because of the app’s rising popularity and the immediate risks that users faced when using the app.

As of the time of disclosure, TeaOnHer was No. 2 in the free app charts on the Apple App Store, a position still held by the app today.

The flaws we found appear to be resolved. TechCrunch can now share how we were able to find users’ driver’s licenses within 10 minutes of being sent a link to the app in the App Store, thanks to easy to find flaws in the app’s public-facing backend system, or API.

The app’s developer, Xavier Lampkin, did not respond to multiple requests for comment after we submitted details of the security flaws, nor would Lampkin commit to notifying affected TeaOnHer users or state regulators of the security lapse.

We also asked Lampkin if any security reviews were carried out before the TeaOnHer app was launched, but we got no reply. (We have more on disclosure later on.)

Alright, start the clock.

TeaOnHer exposed ‘admin panel’ credentials

Before we even downloaded the app, we first wanted to find out where TeaOnHer was hosted on the internet by looking at its public-facing infrastructure, such as its website and anything hosted on its domain.

- [NASA has sparked a race to develop the data pipeline to Mars](#)

- [Why I finally left Spotify](#)

This is usually a good place to start as it helps understand what other services the domain is connected to on the internet.

To find the domain name, we first looked (by chance) at the [app's listing on the Apple App Store](#) to find the app's website. This can usually be found in its privacy policy, which apps must include before Apple will list them. (The app listing also claims the developer “does not collect any data from this app,” which is demonstrably false, so take that as you will.)

TeaOnHer's privacy policy was in the form of a published Google Doc, which included an email address with a `teaonher . com` domain, but no website.

The website wasn't public at the time, so with no website loading, we looked at the domain's public-facing DNS records, which can help to identify what else is hosted on the domain, such as the type of email servers or web hosting. We also wanted to look for any public subdomains that the developer might use to host functionality for the app (or host other resources that [should probably not be public](#)), such as admin dashboards, databases, or other web-facing services.

But when we looked at the TeaOnHer's public internet records, it had no meaningful information other than a single subdomain, `appserver . teaonher . com`.

When we opened this page in our browser, what loaded was the landing page for TeaOnHer's API (for the curious, [we uploaded a copy here](#)). An API simply allows things on the internet to communicate with each other, such as linking an app to its central database.

It was on this landing page that we found the exposed email address and plaintext password (which wasn't that far off "password") for Lampkin's account to access the TeaOnHer "admin panel."

The API page showed that the admin panel, used for the document verification system and user management, was located at "localhost," which simply refers to the physical computer running the server and may not have been directly accessible from the internet. It's unclear if anyone could have used the credentials to access the admin panel, but this was in itself a sufficiently alarming finding.

At this point, we were only about two minutes in.

Otherwise, the API landing page didn't do much other than offer some indication as to what the API can do. The page listed several API endpoints, which the app needs to access in order to function, such as retrieving user records from TeaOnHer's database, for users to leave reviews, and sending notifications.

With knowledge of these endpoints, it can be easier to interact with the API directly, as if we were imitating the app itself. Every API is different, so learning how an API works and how to communicate with one can take time to figure out, such as which endpoints to use and the parameters needed to effectively speak its language. Apps like Postman can be helpful for accessing and interacting directly with APIs, but this requires time and a certain degree of trial and error (and patience) to make APIs spit out data when they shouldn't.

But in this case, there was an even easier way.

TeaOnHer API allowed unauthenticated access to

user data

This API landing page included [an endpoint called /docs](#), which contained the API's auto-generated documentation (powered by a product called Swagger UI) that contained the full list of commands that can be performed on the API.

This documentation page was effectively a master sheet of all the actions you can perform on the TeaOnHer API as a regular app user, and more importantly, as the app's administrator, such as creating new users, verifying users' identity documents, moderating comments, and more.

The API documentation also featured the ability to query the TeaOnHer API and return user data, essentially letting us retrieve data from the app's backend server and display it in our browser.

While it's not uncommon for developers to publish their API documentation, the problem here was that some API requests could be made without any authentication — no passwords or credentials were needed to return information from the TeaOnHer database. In other words, you could run commands on the API to access users' private data that should not have been accessible to a user of the app, let alone anyone on the internet.

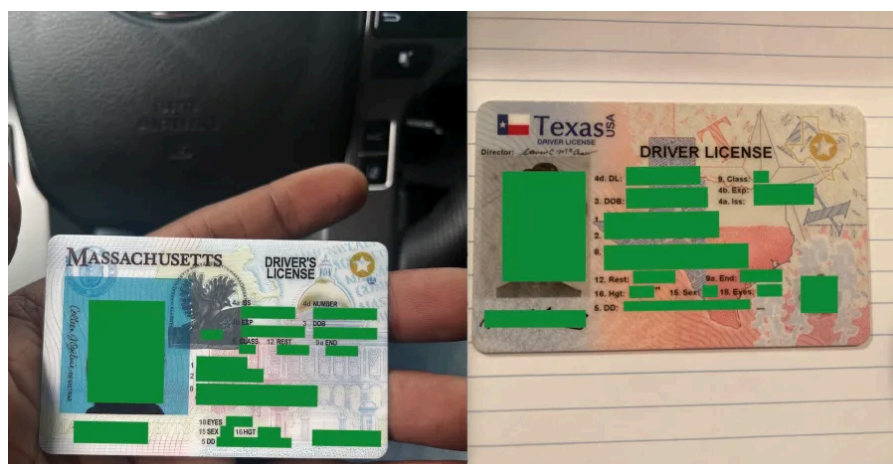
All of this was conveniently and publicly documented for anyone to see.

Requesting a list of users currently in the TeaOnHer identity verification queue, for example — no more than pressing a button on the API page, nothing fancy here — would return dozens of account records on people who had recently signed up to TeaOnHer.

The records returned from TeaOnHer's server contained users' unique identifiers within the app

(essentially a string of random letters and numbers), their public profile screen name, and self-reported age and location, along with their private email address. The records also included web address links containing photos of the users' driver's licenses and corresponding selfies.

Worse, these photos of driver's licenses, government-issued IDs, and selfies were stored in an Amazon-hosted S3 cloud server set as publicly accessible to anyone with their web addresses. This public setting lets anyone with a link to someone's identity documents open the files from anywhere with no restrictions.



TWO DRIVER'S LICENSES (REDACTED BY TECHCRUNCH) EXPOSED BY THE FLAWS IN THE TEAONHER APP

IMAGE CREDITS:TECHCRUNCH (SCREENSHOT)

With that unique user identifier, we could also use the API page to directly look up individual users' records, which would return their account data and any of their associated identity documents. With uninhibited access to the API, a malicious user could have scraped huge amounts of user data from the app, much like what happened with [the Tea app to begin with](#).

From bean to cup, that was about 10 minutes, and we hadn't even logged-in to the app yet. The bugs were so easy to find that it would be sheer luck if nobody malicious found them before we did.

We asked, but Lampkin would not say if he has the technical ability, such as logs, to determine if anyone had used (or misused) the API at any time to gain access to users' verification documents, such as by scraping web addresses from the API.

In the days since our report to Lampkin, the API landing page has been taken down, along with its documentation page, and it now displays only the state of the server that the TeaOnHer API is running on as "healthy." At least on cursory tests, the API now appears to rely on authentication, and the previous calls made using the API no longer work.

The web addresses containing users' uploaded identity documents have also been restricted from public view.

TeaOnHer developer dismissed efforts to disclose flaws

Given that TeaOnHer had no official website at the time of our findings, TechCrunch contacted the email address listed on the privacy policy in an effort to disclose the security lapses.

But the email bounced back with an error saying the email address couldn't be found. We also tried contacting Lampkin through the email address on his website, Newville Media, but our email bounced back with the same error message.

TechCrunch reached Lampkin via LinkedIn message, asking him to provide an email address where we could send details of the security flaws. Lampkin responded with a general "support" email address.

When TechCrunch discloses a security flaw, we reach out to confirm first that a person or company is the correct recipient. Otherwise, blindly sending

details of a security bug to the wrong person could create a risk. Before sharing specific details of the flaws, we asked the recipient of the “support” email address if this was the correct address to disclose a security exposure involving TeaOnHer user data.

“You must have us confused with ‘the Tea app’,” Lampkin replied by email. (We hadn’t.) “We don’t have a security breach or data leak,” he said. (It did.) “We have some bots at most but we haven’t scaled big enough to be in that conversation yet, sorry you were misinformed.” (We weren’t.)

Satisfied that we had established contact with the correct person (albeit not with the response we received), TechCrunch shared details of the security flaws, as well as several links to exposed driver’s licenses, and a copy of Lampkin’s own data to underscore the severity of the security issues.

“Thank you for this information. This is very concerning. We are going to jump on this right now,” said Lampkin.

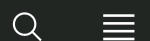
Despite several follow-up emails, we have not heard from Lampkin since we disclosed the security flaws.

It doesn’t matter if you’re a one-person software shop or [a billionaire vibe coding through a weekend](#): Developers still have a responsibility to keep their

Latest Security
Startups AI
Venture Apps
Apple



Events
Podcasts
Newsletters



Topics: [age verification](#) [cybersecurity](#) [data breach](#)

[Exclusive](#) [Security](#) [vibe coding](#)



Zack Whittaker

Security Editor |

Zack Whittaker is the security editor at TechCrunch. He can be reached via encrypted message at [zackwhittaker.1337...](#)

[View Bio](#) >

KEEP READING

SECURITY



HR giant Workday says hackers stole personal data in recent breach

Workday, one of the largest providers of human resources technology, has confirmed a data breach that allowed hackers to steal personal information from one of its third-party customer relationship databases.

In [a blog post published late Friday](#), the HR technology giant said the hackers stole an unspecified amount of personal information from the database, which Workday said was primarily used to store contact information, such as names, email addresses, and phone numbers.

Workday did not explicitly rule out that customer information was taken in the data breach, stating only that there was “no indication of access to customer tenants or the data within them,” which corporate customers typically use to store the bulk of their human resources files and employees’ personal data.

The company said the stolen information may be used to further social engineering scams, where hackers trick or threaten victims into giving them access to sensitive data.

Workday has more than 11,000 corporate customers, serving at least 70 million users around the world, [per the company’s website](#). Bleeping Computer [reports](#) that the hack was discovered on August 6.

Workday did not identify the breached third-party customer database platform, but follows in a recent spate of cyberattacks targeting Salesforce-hosted

Newsletters

[See More ↗](#)

Subscribe for the industry’s biggest tech news

TechCrunch Daily News



Every weekday and Sunday, you can get the best of TechCrunch’s coverage.

Startups Weekly



Startups are the core of TechCrunch, so get our best coverage delivered weekly.

TechCrunch Week in Review



Get the best of our coverage, delivered to your inbox every Saturday.

TechCrunch Mobility



TechCrunch Mobility is your destination for transportation news and insight.

No newsletters selected.

Subscribe

By submitting your email, you agree to our [Terms](#) and [Privacy Notice](#).

databases used by large companies to store customer data. In recent weeks, [Google](#), [Cisco](#), [airline giant Qantas](#), and [retailer Pandora](#) have all had reams of data stolen from their Salesforce databases.

Google attributed the breaches to ShinyHunters, a group of hackers known for using voice phishing to steal corporate data by tricking company employees into granting them access to their cloud-based databases. Google said ShinyHunters was likely in the process of preparing a data leak site to extort its victims into paying the hackers to delete the data, akin to how ransomware gangs operate.

Connor Spielmaker, a spokesperson for Workday, did not comment beyond Workday's blog post or answer TechCrunch's questions, including whether Workday knows how many individuals had data stolen or who the stolen data relates to, such as Workday employees or Workday's corporate customers. Workday would not say if it has the technical means, such as logs, to determine what customer data was exfiltrated.

As of the time of publication, Workday's blog post [disclosing the breach](#) contained a hidden "noindex" tag in its source code, which instructs search engines to ignore the page, making it difficult for anyone searching the web to find the page.

It's not clear for what reason Workday is hiding its data breach notification from search engines.

Do you know more about the Workday data breach or attacks targeting Salesforce databases? Have you been notified about a data breach? Securely contact this reporter via encrypted message at [zackwhittaker.1337](#) on Signal.

Updated with a response from Workday.

We're always looking to evolve, and by providing some insight into your perspective and feedback into TechCrunch and our coverage and events, you can help us! Fill out [this survey](#) to let us know how we're doing and get the chance to win a prize in return!

Topics: [cyberattack](#) [cybersecurity](#) [data breach](#)

[human resources](#) [Salesforce](#) [Security](#)

[Workday](#)



Zack Whittaker

Security Editor |

Zack Whittaker is the security editor at TechCrunch. He can be reached via encrypted message at [zackwhittaker.1337...](#)

[View Bio](#) >

KEEP READING

SECURITY



Allianz Life data breach
affects 1.1 million

customers

Zack Whittaker — 3:26 PM PDT · August 18, 2025

The image shows the Allianz logo in large blue letters on the side of a modern building. The building has a glass facade with vertical lines. The sky is visible in the background.

Allianz

The July data breach at U.S. insurance giant Allianz Life allowed hackers to steal the personal information of 1.7 million customers, according to data breach notification site Have I Been Pwned.

Allianz Life disclosed the data breach in late July, confirming that hackers stole the personal information of [the "majority" of its 1.4 million customers](#) and its employees from a cloud-stored customer relationship database. Allianz has so far refused to confirm exactly how many people are affected by the breach.

IMAGE CREDITS: THE NEW YORK TIMES / GETTY IMAGES

Have I Been Pwned, a [data breach notification site](#) that alerts people when their email address has been caught up in data breaches, said [in a post on Monday](#) the Allianz Life breach includes customers' names, gender, date of birth, email and home addresses, and phone numbers from a database hosted by cloud giant Salesforce.

Allianz Life later told the states of Texas and Massachusetts the hackers also [stole Social Security numbers](#) in the breach.

Brett Weinberg, a spokesperson for Allianz Life, declined to comment to TechCrunch as the company's investigation is ongoing.

Latest in Security

See More

Allianz Life is one of a series of tech and corporate giants that have been targeted in recent months by a hacking crew known as ShinyHunters, a group known for their social engineering skills aimed at tricking employees into granting them access to the company's databases.

[Google](#), [Cisco](#), [airline giant Qantas](#), and [retailer Pandora](#) — and also [HR giant Workday, as reported by TechCrunch on Monday](#) — have also reported recent data thefts related to their Salesforce-hosted data.

The ShinyHunters gang is said to be preparing a data leak site in an attempt to extort victims into paying the hackers to delete the data, a tactic often employed by ransomware gangs. The group reportedly overlaps with other hacking and crime groups, [including Scattered Spider](#) and [The Com](#), a known collective of cybercriminals who use hacking, extortion, and sometimes threats of violence to break into networks.

We're always looking to evolve, and by providing some insight into your perspective and feedback into TechCrunch and our coverage and events, you can help us! Fill out [this survey](#) to let us know how we're doing and get the chance to win a prize in return!

Topics: [allianz life](#) [cybersecurity](#) [insurance](#) [Security](#)

SECURITY



Allianz Life data breach affects 1.1 million customers

Zack Whittaker - 16 hours ago

SECURITY



HR giant Workday says hackers stole personal data in recent breach

Zack Whittaker - 1 day ago

GOVERNMENT & POLICY



How your solar rooftop became a national security issue

Connie Loizos - 4 days ago

[f](#) [X](#) [in](#) [t](#) [✉](#) [🔗](#)



Zack Whittaker

Security Editor | [🦋](#) [@](#) [🏠](#)

Zack Whittaker is the security editor at TechCrunch. He can be reached via encrypted message at [zackwhittaker.1337...](#)

Loading the next article



TechCrunch
Staff

Contact Us

Advertise

Crunchboard
Jobs

Site Map

Terms of
Service

Privacy
Policy

RSS Terms of
Use

Neuralink
Google Chrome
StubHub
Claude
GPT-5
Tech Layoffs
ChatGPT